

REPORT TECNICO: OSSERVARE L'HANDSHAKE A 3 VIE TCP CON WIRESHARK E TCPDUMP

Autore: Leandro Ancona Corso: Cyber Security & Ethical Hacking Istituto: Epicode Data: 16 Giugno 2026

Indice dei Contenuti

- 1. Introduzione e Contesto di Laboratorio
- 2. Topologia e Setup di Rete (Mininet)
- 3. Analisi Pacchetti con Wireshark (Risposte alle Domande)
- 4. Analisi Pacchetti con tcpdump (Opzione -r)
- 5. Domande di Riflessione Finale

1. Introduzione e Contesto di Laboratorio

Il presente report descrive l'attività di laboratorio volta ad analizzare il meccanismo fondamentale di stabilimento delle sessioni TCP: il **Three-Way Handshake (Handshake a 3 vie)**. L'analisi viene condotta all'interno della macchina virtuale *CyberOps Workstation* utilizzando un'infrastruttura simulata tramite **Mininet**. L'obiettivo primario è intercettare, decodificare ed esaminare i flag di controllo (**SYN**, **ACK**), i numeri di sequenza relativi ed assoluti, e la classificazione delle porte sorgente e destinazione coinvolte in una comunicazione HTTP standard tra un client (Host H1) e un server web (Host H4).

2. Topologia e Setup di Rete (Mininet)

La topologia di rete configurata tramite lo script Python `cyberops_topo.py` prevede due macro-sottoreti connesse tramite un router centrale (R1):

DETTAGLIO STRUTTURA INDIRIZZAMENTO IP

H1H4R1

Host / Dispositivo	Interfaccia	Indirizzo IP Network	Ruolo nel Laboratorio
H1-eth0	10.0.0.11 /24	Client Web (Firefox + tcpdump / Wireshark)	
H4-eth0	172.16.0.40 /12	Server Web Apache/HTTP di Destinazione	

Host / Dispositivo	Interfaccia	Indirizzo IP Network	Ruolo nel Laboratorio
Gateway	10.0.0.1 / 172.16.0.1	Routing tra le due subnet distinte	

Il traffico è stato generato navigando dall'host H1 (tramite browser Firefox) verso l'indirizzo del server web `172.16.0.40`, catturando i primi 50 pacchetti con `tcpdump` sull'interfaccia `H1-eth0` e salvando il file in `/home/analyst/capture.pcap` per la successiva ispezione.

3. Analisi Pacchetti con Wireshark

Sulla base della traccia dei pacchetti reali estratta dalla console di laboratorio, di seguito si riportano le risposte puntuali a tutte le domande poste nell'esercitazione.

FRAME 1: PACCHETTO INIZIALE SYN (CLIENT → SERVER)

1. Qual è il numero di porta TCP di origine?

Il numero di porta TCP di origine è **58716** (visibile nella stringa di cattura `10.0.0.11.58716`).

2. Come classificheresti la porta di origine?

Si tratta di una **porta effimera (o dinamica/privata)**. Le porte effimere vengono allocate dinamicamente dal sistema operativo del client per sessioni temporanee e risiedono nel range compreso tra 49152 e 65535 (o nel range esteso di Linux 32768-60999).

3. Qual è il numero di porta TCP di destinazione?

La porta TCP di destinazione è la porta **80**, identificata nel log con l'etichetta del protocollo associato: **http**.

4. Come classificheresti la porta di destinazione?

È una **Well-Known Port (Porta Ben Nota)**. Questo range comprende le porte da 0 a 1023 e identifica servizi di sistema standardizzati dallo IANA, come appunto il protocollo HTTP non sicuro (porta 80).

5. Quale flag è impostato?

È impostato esclusivamente il flag **SYN (Synchronize)**, indicato nei log di tcpdump con la notazione `[S]`. Questo flag indica la richiesta di inizio sincronizzazione dei numeri di sequenza per stabilire una nuova sessione.

6. A quale valore è impostato il numero di sequenza relativo?

Il numero di sequenza relativo è impostato a **0**. Wireshark visualizza il valore iniziale relativo come 0 per semplificare il tracciamento della sessione, sebbene il valore assoluto reale trasmesso nel pacchetto sia un numero casuale a 32 bit (nello specifico, `2432755549`).

FRAME 2: RISPOSTA DEL SERVER SYN-ACK (SERVER → CLIENT)

7. Quali sono i valori delle porte di origine e destinazione?

Porta di Origine: **80 (http)** (il server risponde dalla sua porta di servizio).

Porta di Destinazione: **58716** (il traffico viene indirizzato alla porta effimera precedentemente aperta dal client).

8. Quali flag sono impostati?

Sono impostati contemporaneamente i flag **SYN** e **ACK**, rappresentati sinteticamente dalla notazione `[S.]` nei log. Il server conferma la ricezione del primo pacchetto e invia la propria richiesta di sincronizzazione.

9. A quali valori sono impostati i numeri relativi di sequenza e acknowledgment?

Numero di Sequenza Relativo: **0** (il server inizia la sua sequenza da zero relativo; valore assoluto: `1766419191`).

Numero di Acknowledgment Relativo: **1** (valore assoluto: `2432755550`). Il valore indica che il server si aspetta dal client il byte successivo (Sequence del client iniziale + 1).

FRAME 3: CHIUSURA HANDSHAKE ACK (CLIENT → SERVER)

10. Quale flag è impostato nel terzo e ultimo pacchetto dell'handshake?

È impostato unicamente il flag **ACK (Acknowledgment)**, indicato con un punto fermo `[.]` nella sintassi tcpdump. Questo conferma al server che l'host client ha ricevuto il flag SYN-ACK, completando ufficialmente la transizione dello stato TCP a **ESTABLISHED**.

4. Analisi Pacchetti con tcpdump

Nella terza parte del laboratorio viene analizzato l'utilizzo dell'utility da riga di comando `tcpdump` per ispezionare i file pcap precedentemente salvati.

Cosa fa l'opzione -r nel comando tcpdump?

L'opzione `-r` (**read**) indica a tcpdump di **leggere i pacchetti da un file di cattura salvato precedentemente** (come un file `.pcap`) anziché mettersi in ascolto live intercettando il traffico in tempo reale da un'interfaccia di rete fisica o virtuale. Questo permette l'analisi offline e ripetibile dei dati.

Sintassi eseguita nel laboratorio per estrarre i 3 pacchetti analizzati:

```
[analyst@secOps ~]$ tcpdump -r /home/analyst/capture.pcap tcp -c 3
reading from file capture.pcap, link-type EN10MB (Ethernet)
13:58:30.647462 IP 10.0.0.11.58716 > 172.16.0.40.http: Flags [S], seq 2432755549...
13:58:30.647543 IP 172.16.0.40.http > 10.0.0.11.58716: Flags [S.], seq 1766419191, ack 2432755549...
13:58:30.647544 IP 10.0.0.11.58716 > 172.16.0.40.http: Flags [.], ack 1...
```

5. Domande di Riflessione Finale

RIFLESSIONE E APPLICAZIONE PROFESSIONALE

Domanda 1: Ci sono centinaia di filtri disponibili in Wireshark. Una rete di grandi dimensioni potrebbe avere numerosi filtri e molti tipi diversi di traffico. Elenca tre filtri che potrebbero essere utili a un amministratore di rete.

Tre filtri fondamentali e ad alto valore operativo in ambienti di produzione sono:

- `ip.addr == [IP_Address]` : Isola tutto il traffico (sia sorgente che destinazione) associato a un host specifico. Utilissimo per il troubleshooting di una macchina compromessa o non raggiungibile.
- `http.request.method == "POST"` o `tcp.port == 443` : Consente di monitorare le richieste web specifiche (es. invio dati/credenziali) o di filtrare l'intero traffico cifrato SSL/TLS per analizzare i volumi e i certificati di rete.
- `tcp.flags.reset == 1` : Mostra tutti i pacchetti con il flag RST abilitato. Questo filtro è cruciale per individuare connessioni interrotte bruscamente, malfunzionamenti applicativi, o tentativi latenti di port scanning (es. TCP SYN/Xmas scan).

Domanda 2: In quali altri modi Wireshark potrebbe essere utilizzato in una rete di produzione?

Oltre alla semplice analisi dei pacchetti didattici, in una rete di produzione reale Wireshark viene impiegato per:

1. **Ottimizzazione delle Performance e Troubleshooting:** Identificazione di colli di bottiglia, ritardi di ritrasmissione (TCP Retransmissions), pacchetti duplicati, o latenze anomale causate da errate configurazioni della dimensione massima dei segmenti (MSS/MTU).
2. **Incident Response e Network Forensics:** Analisi post-incidente per verificare l'effettivo raggio d'azione di un attacco, estrarre payload malevoli non cifrati, ricostruire conversazioni VOIP, rilevare tentativi di esfiltrazione dati o attività di malware che comunicano con server di Command & Control (C2).
3. **Rilevamento delle Anomalie e Sicurezza:** Rilevare anomalie protocollari, come pacchetti ICMP eccessivi (Ping Flood), scansioni di rete strutturate, o pacchetti non conformi agli standard RFC che potrebbero indicare tentativi di exploitation o la presenza di software legacy difettoso.